Staff API

BACKEND REFERENCE

OVERVIEW

Basics & auth	Changes in this release	HRA status check	Location URL fields
Add to Calendar (IST)			

STAFF ENDPOINTS

Auth & account	10	Profile	5	Family members	5	Addresses	4
Wallet & coins	5	Cart & diagnostics booking	5	Packages, tests & scans	8	Doctor consultations	9
My bookings	8	HRA (health risk assessment)	5	Notifications	2	Doctor chat	2
Documents & uploads	5	Support & issues	4				

Staff API Reference

Every route in `Routes/StaffRoute.js` with its request payload and success response, plus the HRA status check, the location URL fields on centres, branches, doctors and bookings, and the wallet changes made in this release. Payloads and responses are taken from the controller code. Values shown are examples.

Basics & auth

BASE URL

`{BASE_URL}/api/staff`

AUTH HEADER

`Authorization: Bearer <token>`

TOKEN FROM

`POST /api/staff/login-staff`

BODY FORMAT

`application/json`

unless marked multipart

- **The staff member is always taken from the token.** No staff endpoint takes a `staffId` in the URL, body or query. Other IDs (bookingId, doctorId, familyMemberId…) go in the request body.
- **Auth errors (401):** `Authentication token missing`, `Token has been revoked. Please log in again.`, `Malformed token`, `Invalid or expired token`. A non-staff token gets 403.

- **Errors** come back as `{ "message": "..." }` (some also have `success: false` or `isSuccessfull: false`) with status 400, 402, 404, 409 or 500.
- **409 is new in this release:** returned when the wallet changed while a booking or redemption was being processed, or for a duplicate credit. Show the message and let the user retry.

Several GET endpoints read their input from the JSON body

For example `GET /single-booking` expects `{ "bookingId" }` in the body. Mobile HTTP clients (Dio, OkHttp, axios on React Native) can send a body with GET. Browser `fetch()` cannot. These endpoints are marked "GET with body" below.

Changes in this release

AREA	WHAT CHANGED	ENDPOINTS
Wallet engine	New `Utils/wallet.js`. Every credit and debit updates the category, `wallet_balance`, `totalAmount` and the transaction history in one atomic update. Debits fail with 409 if the category no longer has enough balance.	All booking, cancel, coin and admin credit endpoints
Cancel booking	Already Cancelled or Completed bookings can't be cancelled again. The full booking price is refunded to the matching category (tests / doctors / packages) with a "Booking Cancellation" history entry. Response adds `refundedAmount`, `refundedTo`.	`PUT /cancel-booking`
Coins	Redeemed coins go to the **Doctors** wallet (1 coin = ₹1) with a "Coins Redemption" history entry. Coins can't be redeemed twice. Steps must be a whole number 1–100,000 per request.	`/addsteps`, `/steps`, `/redeemcoins`
Bookings	Wallet deduction now happens atomically after the online payment is verified. New 409 response if the balance changed meanwhile.	`/create-bookings`, `/package-bookings`, `/consultationbooking`, `/process-payment`
Doctor rating	New `rating` field on doctors (0-5, one decimal, default 0), set by the admin on create/update. Returned in doctor details in booking responses and `/getonlinebookingdoctors`.	`/api/admin/create-doctor`, `/update-doctors`, `/update-doctor`, `/single-booking`, `/mybookings`, `/getonlinebookingdoctors`
Add to Calendar	Booking responses include a `calendar` object with IST start and end times, display text and a Google Calendar link.	See Add to Calendar (IST)

Location URL	Centres, branches and doctors have a `locationUrl` (Google Maps link). It is copied onto Center Visit and Offline bookings and returned in booking responses.	See Location URL fields
Admin wallet protection	Admin profile edit and Excel import can no longer change wallet fields. Admin credits reject the same credit within 10 seconds (409). Admin package bookings pay from the packages wallet.	`/api/admin/editstaff`, `/addamount`, `/add-amount-to-all`
Wallet data	All staff wallets were reset to ₹0. Old balances and history are archived in the `wallet_log_archives` collection.	`GET /wallet`

HRA status check

Use `GET /hra-submission-status` to check whether the staff member has already taken the HRA (Health Risk Assessment) in the last 30 days, before showing the test.

REQUEST

```
GET /api/staff/hra-submission-status
Authorization: Bearer <token>
(no body)
```

RESPONSE · NEVER TAKEN

```
{
  "success": true,
  "message": "No HRA submission found. Staff
  "data": {
    "hasTakenInLast30Days": false,
    "canTakeHra": true,
    "lastSubmission": null,
    "nextEligibleDate": null,
    "daysRemaining": 0
  }
}
```

RESPONSE · TAKEN 10 DAYS AGO

```
{
  "success": true,
  "message": "HRA already taken in the last
  "data": {
    "hasTakenInLast30Days": true,
    "canTakeHra": false,
    "nextEligibleDate": "2026-10-29T06:30:00
    "daysRemaining": 20,
    "lastSubmission": {
      "submissionId": "6702f1...",
      "submittedAt": "2026-09-29T06:30:00.00
      "totalPoints": "68/100"
```

```
      totalPoints : "68/100",
      "riskLevel": "Moderate",
      "riskMessage": "...",
      "categoryPoints": { "Lifestyle": 18, "
      "prescribedForCategories": { "Diet": "
    }
  }
}
```

- **Show the test** when `data.canTakeHra` is `true`. Otherwise show `daysRemaining` / `nextEligibleDate` and the last result.
- `totalPoints` is a string out of 100 (male) or 120 (female), based on the staff member's gender.
- Submit answers with `POST /submit-hra-answers`. The question list comes from `GET /allhracat`.

Location URL fields

`locationUrl` is a Google Maps share link. Use it for the "View Directions" button. It is set by admins on centres, branches and doctors, and copied onto bookings when the visit is in person.

WHERE	KEY NAME	WHEN IT HAS A VALUE
Diagnostic centre	`diagnostic.locationUrl`	When the admin set it
Centre branch	`diagnostic.branches[].locationUrl`	When the admin set it
Doctor (clinic)	`doctor.locationUrl`	When the admin set it
Diagnostic / package booking	`booking.locationUrl` and top-level `locationUrl`	`serviceType: "Center Visit"` only, otherwise `null`
Doctor consultation booking	`booking.locationUrl` and top-level `locationUrl`	`type: "Offline"` only, otherwise `null`

Validation (admin create / update)

- Must be `https://` on `maps.app.goo.gl`, `maps.google.com`, `goo.gl/maps`… or `google.com/maps`….
- Empty string, `null`, `"null"` or `"undefined"` clears it (stored as `null`).
- Invalid link → `400 { "message": "locationUrl must be a Google Maps link (e.g. https://maps.app.goo.gl/...)" }`
- On update, leaving `locationUrl` out keeps the current value.

Admin endpoints that accept `locationUrl` (doctor endpoints also accept `rating`)

Admin endpoints that accept `locationUrl` (doctor endpoints also accept `lat`/`lng`)

POST	`/api/admin/create-diagnostics`	Creates a diagnostic centre with its branches (main create).
POST	`/api/admin/create-diagnostic`	Older JSON create for a diagnostic centre.
PUT	`/api/admin/update-diagnostic`	Updates any centre fields, including locationUrl.
POST	`/api/admin/add-branch`	Adds a branch to a centre.
PUT	`/api/admin/update-branch`	Updates a branch. Fields left out keep their value.
POST	`/api/admin/create-doctor`	Creates a doctor. locationUrl is the clinic's Maps link.
PUT	`/api/admin/update-doctors`	Updates a doctor (by doctorId).
PUT	`/api/admin/update-doctor`	Updates a doctor (by id).

Add to Calendar (IST)

Every booking response now has a `calendar` object. All times are Indian Standard Time (Asia/Kolkata, UTC+05:30). Each slot is 30 minutes.

FIELD

```
"calendar": {
  "start": "2026-10-12T10:00:00+05:30",
  "end": "2026-10-12T10:30:00+05:30",
  "timezone": "Asia/Kolkata",
  "displayDate": "12 Oct 2026",
  "displayTime": "10:00 AM - 10:30 AM IST",
  "googleCalendarUrl": "https://calendar.goc
}
```

HOW TO USE IT

- **"Add to Calendar" button:** open `googleCalendarUrl`. Google Calendar opens with the title, IST time, booking ID and location filled in.
- **Other calendars (Apple, Outlook, device):** use `start` and `end`. They carry the +05:30 offset, so no conversion is needed.
- **Showing the slot on screen:** use `displayDate` and `displayTime`.
- **Title:** "Doctor consultation - Dr. {name}", "Health

package - {package} at {centre}" or "Diagnostic test - {centre}".

- **Location:** the `locationUrl` (Center Visit / Offline) or the meeting link (online consultation).
- `calendar` is `null` when a booking has no date or time slot.

Returned by: `POST /create-bookings`, `POST /package-bookings`, `POST /consultationbooking`, `PUT /reschedulebooking`, `PUT /diagreschedule`, `PUT /packagereschedule`, `GET /mybookings` (each booking) and `GET /single-booking`.

Staff endpoints

Filter by path, field or description (e.g. bookingIc

Changed in this release only

77 of 77 endpoints

Auth & account

POST `/api/staff/login-staff` — NO AUTH

Log in with email or phone number. Returns the token used by every other endpoint.

POST `/api/staff/logout`

Revokes the current token.

POST `/api/staff/save-fcm-token`

Saves the device's Firebase push token.

POST `/api/staff/verify-email`

Checks that the email belongs to the logged-in staff member.

Auth	Bearer token (staff)
Content type	application/json

REQUEST

```
{
  "email": "staff@example.com"
}
```

SUCCESS RESPONSE · 200

```
{
  "message": "Email verified successfully"
  "staffId": "66f1..."
}
```

POST /api/staff/reset-password

Sets a new password for the logged-in staff member.

Auth: Bearer token (staff)

Content type: application/json

REQUEST

```
{
  "newPassword": "newSecret1",
  "confirmPassword": "newSecret1"
}
```

SUCCESS RESPONSE · 200

```
{
  "message": "Password reset successfully
}
```

PUT /api/staff/changepassword

Changes the password after checking the current one.

Auth: Bearer token (staff)

Content type: application/json

REQUEST

```
{
  "currentPassword": "secret123",
  "newPassword": "newSecret1"
}
```

SUCCESS RESPONSE · 200

```
{
  "message": "Password updated successfull
}
```

POST /api/staff/forgot-password

NO AUTH

Sets a new password by email.

Auth: None

Content type: application/json

REQUEST

```
{
  "email": "staff@example.com",
  "newPassword": "newSecret1"
}
```

SUCCESS RESPONSE · 200

```
{
  "message": "Password updated successfull
}
```

POST /api/staff/deleteaccount

Requests account deletion. Sends a confirmation email.

GET `/api/staff/confirm-delete-account/:token` — NO AUTH

Link opened from the confirmation email. Deletes the account.

Auth	None
Content type	None
URL params	`:token from the email`

REQUEST

```
No body
```

SUCCESS RESPONSE · 200

```
{
  "message": "Your account has been succes
}
```

DELETE `/api/staff/deleteaccount`

Deletes the logged-in staff account immediately (no email step).

Profile

GET `/api/staff/getprofile`

Profile with wallet balance, family, bookings and wallet history.

GET `/api/staff/staffprofile`

Profile with health details.

PUT `/api/staff/editprofile`

Updates profile fields. Send only the fields to change.

POST `/api/staff/uploadProfileImage`

Uploads a profile photo.

PUT `/api/staff/updateProfileImage`

Replaces the profile photo. Without a file the existing one is kept.

Family members

POST `/api/staff/create-family`

Adds a family member.

GET	`/api/staff/get-singlefamilymem` One family member.	GET WITH BODY
GET	`/api/staff/getallfamily` All family members.	
PUT	`/api/staff/updatefamily` Updates a family member. Same fields as create.	
DELETE	`/api/staff/removefamily` Removes a family member.	

Addresses

POST	`/api/staff/create-address` Adds an address. Each addressType (Home, Office, any name) can exist only once.	
GET	`/api/staff/getaddresses` All saved addresses. Use an address _id as addressId for Home Collection bookings.	
PUT	`/api/staff/update-address` Updates an address. Fields left out keep their value.	
DELETE	`/api/staff/remove-address` Removes an address.	

Wallet & coins

GET	`/api/staff/wallet` Wallet balance per category and full transaction history (newest first).	CHANGED
POST	`/api/staff/wallet-request` Asks the admin for wallet money. Only one pending request at a time.	
POST	`/api/staff/addsteps` Adds steps to today's total and recalculates available coins (100 coins per 10,000 steps).	CHANGED

GET `/api/staff/steps` — CHANGED
Step history with coins per day.

POST `/api/staff/redeemcoins` — CHANGED
Moves all available coins into the Doctors wallet (1 coin = ₹1).

Cart & diagnostics booking

POST `/api/staff/addcart`
Adds a test or scan to the cart, or changes its quantity.

GET `/api/staff/mycart` — GET WITH BODY
Cart items and total.

DELETE `/api/staff/deletecart`
Removes an item from the cart.

GET `/api/staff/diagnosticslots` — GET WITH BODY
Available slots of a diagnostic centre for a date.

POST `/api/staff/create-bookings` — CHANGED LOCATIONURL
Checks out the cart into a diagnostics booking. Paid from the Tests wallet, the rest online.

Packages, tests & scans

GET `/api/staff/stafftestpackages`
Packages for the staff member's age and gender, plus their assigned tests and scans.

GET `/api/staff/singlestafftestpackages` — GET WITH BODY
One package with its tests expanded.

POST `/api/staff/addpackages`
Adds a package of a diagnostic centre to the staff member.

GET `/api/staff/getpackage-test`
Staff member's packages and tests.

GET `/api/staff/getscans`
Scans (X-ray etc.) available to the staff member.

GET `/api/staff/gettests`
Tests available to the staff member.

POST `/api/staff/package-bookings` CHANGED LOCATIONURL
Books a health package. Paid from the Packages wallet, the rest online.

GET `/api/staff/recent-package-booking`
The most recent package booking.

Doctor consultations

GET `/api/staff/doctor-slots` GET WITH BODY
A doctor's slots for a date.

POST `/api/staff/consultationbooking` CHANGED LOCATIONURL
Books a doctor consultation. Paid from the Doctors wallet, the rest online.

GET `/api/staff/getonlinebookingdoctors` CHANGED
Doctors that offer online consultations, with their slots.

GET `/api/staff/recent-doctor-booking`
The most recent doctor booking.

GET `/api/staff/getdoctorappointment` GET WITH BODY
Doctor bookings of the staff member, optionally filtered by status.

Auth	Bearer token (staff)
Content type	application/json

REQUEST BODY (SENT WITH GET)

```
{
  "status": "Confirmed (optional)"
}
```

SUCCESS RESPONSE · 200

```
{
  "message": "Doctor appointments fetched
  "staff": {
    "staffId": "66f1...",
```

```
    "name": "...",
    "wallet_balance": 2200
  },
  "appointments": [
    {
      "_id": "bk03...",
      "doctor": "{ ... }",
      "date": "2026-10-12",
      "timeSlot": "10:00 AM",
      "status": "Confirmed"
    }
  ]
}
```


GET `/api/staff/getPrescription` — GET WITH BODY

Doctor appointments with their prescriptions.

Auth	Bearer token (staff)
Content type	application/json

REQUEST BODY (SENT WITH GET)


```
{
  "status": "Completed (optional)"
}
```


SUCCESS RESPONSE · 200


```
{
  "message": "Appointments and prescriptic
  "appointments": [
    {
      "bookingId": "bk03...",
      "doctorPrescriptions": [
        "uploads/..."
      ]
    }
  ]
}
```


POST `/api/staff/bookappoint`

Older appointment flow: creates an appointment to be paid with /process-payment.

GET `/api/staff/getappoint` — GET WITH BODY

One appointment from the older flow.

POST `/api/staff/process-payment` — CHANGED

Pays an older-flow appointment from the Doctors wallet.

My bookings

GET	`/api/staff/mybookings` All bookings (diagnostics, packages, doctors), newest date + time first.	CHANGED	LOCATIONURL	
GET	`/api/staff/single-booking` Full details of one booking.	CHANGED	LOCATIONURL	GET WITH BODY
GET	`/api/staff/getalldiagbookings` Diagnostic bookings, optionally filtered by status.			GET WITH BODY
PUT	`/api/staff/cancel-booking` Cancels a booking and refunds the full booking price to the matching wallet category.			CHANGED
PUT	`/api/staff/reschedulebooking` Moves a doctor consultation to another slot.	CHANGED	LOCATIONURL	
PUT	`/api/staff/diagreschedule` Moves a diagnostic booking to another slot.	CHANGED	LOCATIONURL	
PUT	`/api/staff/packagereschedule` Moves a package booking to another slot.	CHANGED	LOCATIONURL	
GET	`/api/staff/download-report` Downloads the booking as a PDF.			GET WITH BODY

HRA (health risk assessment)

GET	`/api/staff/hra-submission-status` Checks whether the staff member took the HRA in the last 30 days. Call before showing the test.	
POST	`/api/staff/submit-hra-answers` Submits HRA answers and returns the score and risk level.	
GET	`/api/staff/allhracat` HRA categories and their questions for the staff member.	

`POST` `/api/staff/submit-hra`